PrivateAI (CometRow): Which Professional Segments to Target First — Evidence-Based Segment Analysis (October 2026)

PrivateAI's best first customers are small German professional-secrecy practices (sole and small tax-advisory practices first, then small law firms in confidential-heavy practice areas). They already use or want AI, their chambers now say in writing that client data must not go into public chatbots unless the provider is bound to secrecy and data is anonymised, and the buyer is the owner, who can sign in days. The catch is that the product's two strongest legal hooks are still missing: a §203-compliant secrecy/DPA chain and confirmed EU inference. Without them, PrivateAI loses this segment to Privatemode (German, EU-hosted, attested, ISO 27001-certified).

TL;DR

- **Who it really helps:** Berufsgeheimnisträger in small practices — tax advisers (53,932 practices in Germany, 67.1% sole practices) stb-web and lawyers (167,547 admitted on 1 Jan 2026, per BRAK's own statistics). BStBK (Jan 2026) and BRAK (Dec 2024) both say client data may only reach AI providers that are legally and contractually bound to secrecy, and that inputs should be abstracted or anonymised. iww haufe That makes "attested enclave + browser-side masking" a direct answer to written chamber guidance, not just a nice idea. For them it is a compliance-enabler, close to must-have *only* if they already want AI daily. It is not life-saving.
- **Who it does NOT help yet:** hospitals, GKV-funded practices processing patient data (§393 SGB V requires a C5 Type 2 attestation since 1 July 2025), kliniknrw large enterprises (SOC 2/SSO/SLA), and — ethically — high-risk individuals such as sources, activists and survivors. For the high-risk group the need is life-or-death, but a non-anonymous, US-processed service with an imperfect attestation verifier and 14/22 masking recall does not meet the bar.
- **What to do now:** fix the legal stack first: §203/§62a secrecy agreement chain, DPA, EU inference (or an EU-hosted attested backend). Then run a 4-week validation with 10 sole tax advisers and 10 small-firm lawyers at €29/€49/€79 per seat. Meter web search, because at ~$0.05/request search, not model inference, is the dominant cost for heavy users.

Key Findings

Verified facts (primary or near-primary sources):

- **Shadow AI is real and growing in Germany.** Bitkom surveyed 604 firms with ⩾20 staff (Oct 2025). 8% report widespread private AI use (2024: 4%) and 17% isolated cases; four in ten assume employees use private AI accounts. Only 26% provide official generative AI access, with another 17% planning to. wysor bitkom
- **Tax advisers face the clearest rules.**
  - The BStBK FAQ "KI im steuerberatenden Berufsstand" (Stand 27 Jan 2026, legal status July 2025) cites §57 StBerG, §62a StBerG and §203 StGB. It says confidential client data may only go to AI service providers that are "rechtlich und vertraglich strikt an die Verschwiegenheit gebunden". Information allowing inferences about the client or mandate must not be entered into ChatGPT-type tools. haufe + 2
  - The Steuerberaterkammer Hessen published a more detailed orientation guide (Stand 28 July 2026). It covers §62a checks (text-form secrecy obligations, sub-processors, foreign transfers) and warns against blanket client "waivers". stbk-hessen

- **Lawyers face similar rules.** The BRAK "Hinweise zum Einsatz von KI" (Dec 2024, published Jan 2025) says:
  - §43a(2) BRAO secrecy applies fully to LLMs.
  - Disclosure to AI vendors is only allowed under §43e BRAO.
  - Queries should be abstract, and documents should be anonymised before upload. iww dacuro
- **Doctors are told general-purpose LLMs are unsuitable.** The Bundesärztekammer's statement "KI in der Medizin" (board decision 14 Jan 2025) is summarised by the Berlin psychotherapists' chamber as finding that general-purpose LLMs such as ChatGPT offer "keine hinreichend datenschutzkonforme Umgebung" for patient data. psychotherapeutenkamme… bundesaerztekammer
- **The psychotherapists' chamber has no final guidance yet.** BPtK said in late 2025 it is drafting an AI guidance document. It names unclear data flows and possible breaches of confidentiality as real risks. psychotherapeutenjournal
- **§393 SGB V gates GKV health data.** SGB V providers (contract doctors, psychotherapists and others) and their processors may use cloud services for health data only with a current C5 Type 2 attestation (since 1 July 2025) and only in permitted locations. BVMed's January 2026 info sheet says it does not apply outside statutory health insurance. bvmed bvmed
- **Data protection authorities give checklists, not product approvals.** The Datenschutzkonferenz Orientierungshilfe "KI und Datenschutz" (6 May 2024) is a checklist for controllers: purpose, legal basis, DPA or joint controllership, output accuracy. datenschutzticker gleisslutz
- **Enforcement is weaker than headlines suggest; litigation exposure is the more concrete risk.**
  - Italy's Garante fined OpenAI €15M (Dec 2024). The Court of Rome annulled the fine on 18 March 2026 on one-stop-shop jurisdiction grounds, without ruling on the merits. airiskaware gdprfine
  - A more concrete risk signal is litigation exposure. In NYT v. OpenAI, a 13 May 2025 order forced OpenAI to keep consumer ChatGPT logs that would otherwise have been deleted, until 26 Sept 2025. On 7 Nov 2025 the court ordered 20 million de-identified logs produced to plaintiffs. Enterprise tiers were excluded. llms-for-lawyers
- **The competitive field is crowded and well-funded.**
  - Privatemode (Edgeless Systems, German, EU-hosted): free tier of 5M tokens plus 1M per month; pay-as-you-go from €0.43/1M input and €1.27/1M output tokens; enterprise SSO/SLA on request. privatemode omr
  - Confer: free tier of 20 messages/day; $34.99/month. In March 2026 Confer announced its privacy technology will underpin Meta AI. aiinsightsnews alecmuffett
  - Maple: Free; Pro $20; Max $100; Team $30 per user per month (minimum 2 seats). trymaple trymaple
  - Tinfoil Chat: $20/month. tinfoil
- **Your upstream provider (Tinfoil) has real gaps for German buyers.** Its privacy policy (effective 12 Oct 2026) says personal data "may be processed in the United States", with Standard Contractual Clauses for EEA users. tinfoil No EU inference region is published. Tinfoil has completed a SOC 2 Type II examination and offers a DPA, but I found no ISO 27001. tinfoil API price for gpt-oss-120b is $0.15/1M input and $0.60/1M output. trustedrouter tinfoil The web-search fee is not published; a docs example implies ~$0.05 per request. tinfoil

- **Hardware attestation is not absolute.** TEE.fail (Oct 2025) showed that someone with physical access, using a DDR5 memory-bus interposer, can extract attestation keys from Intel TDX and AMD SEV-SNP. tinfoil Those keys can be used to forge NVIDIA GPU confidential-computing attestation. thehackernews gbhackers

My inferences (not directly sourced):

- The legal wedge is the "possibility of knowledge" test. Under §203, enabling the provider to *possibly* see secrets can already count as disclosure. ironum An attested architecture where the operator cannot read plaintext is a strong argument, but no chamber or court has endorsed it yet. A short legal opinion (Gutachten) from a professional-law specialist would be your single most valuable sales asset.
- Masking is your real differentiator against Privatemode, Confer and Maple, because BRAK and BStBK both explicitly ask for anonymisation. But with 14/22 recall it must be sold as "assisted redaction with review", never as anonymisation.

1. Evidence of Real Demand

Signal	Source type	What it shows	Strength
Bitkom: 8% widespread + 17% isolated shadow-AI use; only 26% of firms provide sanctioned AI	Representative survey (604 firms, Jul–Aug 2025) wysor	Demand exists; supply of sanctioned tools lags	Strong
BStBK FAQ (Jan 2026), StBK Hessen guide (Jul 2026)	Chamber guidance	Tax advisers need secrecy-bound providers plus anonymisation	Strong (normative)
BRAK KI guide (Dec 2024)	Chamber guidance	Abstract queries, anonymised documents, §43e contracts	Strong (normative)
legal-tech.de survey 2025 (~80 respondents, 50% sole practitioners): 16% use a concrete AI tool, ~64% want to invest within 12 months, >50% use ChatGPT often or sometimes legal-tech	Small, self-selected survey	Solo lawyers use ChatGPT informally but haven't bought tools	Weak–medium
Anwaltsblatt column: 70–80% probability of shadow AI in firms >5 staff anwaltverein	Practitioner estimate, not a survey	Directional only	Weak
Harmonic Security "The AI Tightrope" (Q1 2025, 176,000+ prompts, 8,000 enterprise users): 45.4% of sensitive AI interactions came from personal email accounts; its Q3 2025 report puts exposures via free/personal AI accounts at 11.84%	Vendor telemetry (security vendor)	Directional; vendor-authored, and the figure varies sharply between reports	Weak
NYT v. OpenAI log preservation/production	Court orders	Consumer AI chats can become evidence	Strong (risk signal)
BÄK: general LLMs not a compliant environment for patient data	Medical chamber	Doctors are told not to use ChatGPT for patient data	Strong (normative)

Interpretation: Demand evidence is strongest where a chamber has formally written down the problem: tax advisers and lawyers. For other listed professions I found no 2025–2026 primary survey data in this research: notaries, insurers, recruiters, HR, M&A, consultants, financial advisers. Treat those segments as hypotheses.

2. Segment Profiles

Segment (DE)	Size	Typical per-seat AI budget	Buyer / cycle	Gating compliance	Sellable in 12 months without certifications?
Sole/small tax practices	53,932 practices; 67.1% sole practices; 89,549 StB (1 Jan 2026) bstbk	Low–medium. Generic tools ~€20–50; inference	Owner, often advised by external DPO; 2–8 weeks (inference)	AVV/DPA, §62a StBerG secrecy chain incl. sub-processors, DPIA likely, EU transfer questions tax-tech	**Yes**, if DPA + §62a agreements + EU region exist
Small law firms (esp. migration, family, criminal, employment)	167,547 lawyers (1 Jan 2026, BRAK statistics; 166,504 a year earlier)	Legal-specific: Beck-Noxtua PLUS €299 / PREMIUM €499 per licence per month plus VAT (ki-tools.com, Oct 2026; 4-week trial, then 6-month minimum term); Lulius €99 solo; generic €20–50	Partner; 2–8 weeks (inference)	§43a/§43e BRAO, §203 StGB, DPA	**Yes**, same conditions; quality gap vs legal-content tools is a risk
Boutique M&A / consultants / IP-sensitive software SMEs	Not verified	Medium–high (inference)	Founder/partner; IT lead in larger firms	NDA/trade secrets; DPA; SOC 2 asked once >50 staff	**Partly**: only micro-firms; frontier-model quality expectations hurt
Private-practice psychotherapists/coaches	Not verified in this research	Low	Individual	§203 (therapists, not coaches); §393 SGB V if GKV-licensed; BPtK	**Risky**: legal opinion needed first; GKV practices effectively blocked

Segment (DE)	Size	Typical per-seat AI budget	Buyer / cycle	Gating compliance	Sellable in 12 months without certifications?
				guidance pending	
Journalists / NGOs	Not verified	Very low individually; grant-funded orgs	Editor/security lead	Threat model, not paperwork	Only as design partners, not revenue
Hospitals, GKV practices, insurers, large enterprises	—	High	Procurement, CISO; 6–18 months	C5 Type 2, ISO 27001, SOC 2, SSO, SLA	**No**

3. Incumbents and the Real Gap

Incumbent	Strength	Gap PrivateAI could fill
Microsoft 365 Copilot + Berufsgeheimnisträger-Zusatzvereinbarung	Already in the stack; Microsoft offers a §203 secrecy addendum	Policy/contract-based, not verifiable; plaintext visible to provider
Beck-Noxtua, Libra, Lulius (legal)	German legal content, citations; Beck-Noxtua claims BSI C5/ISO 27001	Expensive per seat; trust is contractual; no client-side redaction
Privatemode (Edgeless)	German, EU, attested, ISO 27001, API + chat, free tier maple	**Your closest rival.** Gap is narrow: browser masking, profession-specific workflows, German professional-law onboarding
Confer / Maple / Tinfoil Chat	Strong crypto brands, cheap consumer plans	Consumer-oriented, US-based; no German §203 paperwork or professional workflows
Lumo, Duck.ai, Brave Leo, Venice	Free/cheap, policy-based privacy	Not verifiable; no professional compliance posture
Local/on-prem LLMs	Data never leaves the office	Hardware/IT burden for a 3-person practice; weaker models

Interpretation: "Verifiable private chat" alone is not a gap anymore — four rivals already sell it, and Privatemode does so from Germany with certifications. The defensible gap is narrower. It means combining three things for small German secrecy-bound practices:

- attested inference with an EU location;
- a ready-made §203/§62a/§43e paperwork pack;

- redaction-before-send that matches chamber guidance, plus task templates (Einspruch drafts, Mandantenbriefe, Schriftsatz outlines).

4. Acute-Need Individuals and Small Groups: Honest Evaluation

Group	Pain	Can pay?	Fit with current product	Verdict
Investigative journalists & sources	Extreme	Low; newsrooms sometimes	Not anonymous; account + IP metadata visible to infrastructure; US processing; TEE.fail-class physical attacks tinfoil	Do not market as source protection; maybe a newsroom design partner for document triage
Activists / NGOs in high-risk countries	Life-safety	Grant-dependent	Same issues; also device seizure risk (device-only history helps but is not deniable)	Avoid until threat model is documented and independently reviewed
Domestic-violence / survivor support orgs	High	Very low	Caseworker drafting could fit; survivors themselves should not rely on it	Only via org partners, with clear limits
Therapists / coaches	High (§203 for therapists)	Low–medium	Masking helps; §393 blocks GKV contexts	After legal opinion, private-pay practices only
Whistleblowers	Extreme	No	Not anonymous; wrong tool	Explicitly exclude in marketing
Immigration lawyers	High (clients at risk)	Medium	Good fit as a law-firm sub-niche	Include in Segment 2
Individuals with sensitive health/finance/legal issues	Medium–high	€0–20	Fits “private content, not anonymous”	Consumer track; not the B2B wedge

Ethics: For people whose safety depends on secrecy, an overclaim is worse than no product. If you serve them at all, publish:

- a plain-language threat model (“protects content from the operator; does not hide who you are; does not protect against a seized unlocked device or a compromised provider data centre”);
- the known verifier gaps (no freshness/revocation checks).

5. Ranked Top Segments for the First 12 Months

Rank	Segment	Pain	Reachability	WTP	Compliance burden	Competitive risk	Overall
1	Sole/small tax-advisory practices	High (explicit BStBK rule)	High (regional chambers, DStV associations, DATEV community)	Medium	Medium (§62a chain, DPA, EU)	Medium (Privatemode, Copilot, DATEV tools — not researched)	**Best**
2	Small law firms in sensitive practice areas (migration, family, criminal, employment)	High	High (local Anwaltvereine, forums, LinkedIn)	Medium–high	Medium (§43e, DPA)	High (Beck-Noxtua, Lulius, Libra)	**Strong**
3	Boutique M&A/due-diligence advisers, independent consultants, small IP-sensitive software firms	Medium–high	Medium (LinkedIn, founder networks)	Higher	Low–medium (NDA/DPA)	High (ChatGPT Business/Enterprise no-training terms; frontier quality)	**Opportunistic**
4	Newsrooms / digital-rights NGOs (design partners)	Extreme	Medium (Netzwerk Recherche, RSF digital-security desks)	Low	Low paperwork, high threat-model burden	Medium (Confer, Maple)	**Credibility, not revenue**
5	Private-pay psychotherapists (after legal opinion)	High	Medium (chambers, associations)	Low–medium	High (§203, BPtK guidance pending, §393 if GKV)	Low–medium	**Later**

Cheap validation tests (4–6 weeks, <€500):

- **Tax advisers (Rank 1):**
  - *Where to find 10:* LinkedIn search “Steuerberater Einzelkanzlei”, DStV regional associations, regional Steuerberaterkammer events, DATEV community threads.
  - *Offer:* a 30-min interview on “how do you handle AI and Mandantendaten today?”, then a free 4-week pilot. The pilot includes a pre-filled §62a/AVV pack and a redaction demo on a

sample Steuerbescheid.
    - *Price test:* show three anchors — €29 / €49 / €79 per seat per month, with a solo plan.
    - *Pass criterion:* ≥3 of 10 sign a paid pilot or prepay.
- **Lawyers (Rank 2):**
    - *Where to find 10:* local Anwaltvereine, lawyer forums (Beck-Noxtua pricing is debated openly there), LinkedIn migration/family-law groups.
    - *Value proposition:* test it against Beck-Noxtua/Lulius: "redact-then-ask for drafting and correspondence", not legal research.
    - *Price test:* same price ladder.
- **Consultants/M&A (Rank 3):**
    - Run 10 LinkedIn outreach interviews.
    - Test whether open-weight model quality is acceptable on their real tasks, e.g. a redacted CIM summary.
- **NGO/newsroom (Rank 4):**
    - Find 2–3 design partners through digital-security trainers.
    - Free access in exchange for a threat-model review.
- **Low-cost channels:** chamber/association newsletters and webinars, Anwaltsblatt and Steuerberater trade media guest articles, Legal Tech Verband events, re:publica, LinkedIn content explaining the BRAK/BStBK rules.

6. Segments to Avoid for Now

- **Hospitals, MVZ, GKV-licensed practices processing patient data.** §393 SGB V requires a current C5 Type 2 attestation of the data-processing entity, and processing only in permitted locations. bvmed blackfort-tec You have neither.
- **Large enterprises, banks, insurers, public sector.** They require SOC 2/ISO 27001, SSO, SLAs and long procurement. Financial-sector outsourcing rules apply too (not researched here — inference).
- **HR departments in larger firms.** Employee-data processing typically triggers works-council co-determination and a DPIA (inference). The sales cycle is long.
- **Whistleblowers and at-risk sources as marketed users.** The product is not anonymous; overclaiming creates ethical and liability risk.

7. Pricing Sanity Check

Assumptions (mine):

- Tinfoil gpt-oss-120b at $0.15/1M input and $0.60/1M output. tinfoil
- Search at ~$0.05 per request.
- Light user: 300 requests per month, 3,000 input / 700 output tokens each, 10% with search.
- Heavy user: 3,000 requests per month, 8,000 input / 1,500 output tokens (documents, reasoning), 1,000 searches.

Profile	Inference cost	Search cost	Total/month	At €29	At €49
Light	~$0.26	~$1.50	**~$1.76**	Very high margin	Very high margin
Heavy, uncapped search	~$6.30	~$50.00	**~$56**	Loss	Thin/negative
Heavy, 200 searches cap	~$6.30	~$10.00	**~$16**	OK	Good
Heavy on Privatemode API instead (€0.43/€1.27 per 1M)	~€16	depends	~€16 + search	OK	Good

Benchmarks:

- Generic private chat: Tinfoil Chat $20, Maple Pro $20, Maple Team $30/user, Confer $34.99. tinfoil trymaple
- Legal-specific tools: Lulius €99 solo; Beck-Noxtua PLUS €299 / PREMIUM €499 per licence per month plus VAT (ki-tools.com, Oct 2026).

Conclusion: €29–49 per seat per month is plausible for professionals, if the price includes the compliance pack and redaction. Tokens are cheap; **search is the cost risk.** Include about 100–200 searches per month and sell more as an add-on. Route default lookups to Brave Search only if its current API price and DPA check out (not verified here).

8. Open Risks and Unknowns You Must Verify

1. **Inference region.** Tinfoil's policy points to US processing under SCCs. Ask privacy@tinfoil.sh for an EU region and a region-specific DPA. tinfoil Alternatively, evaluate Privatemode's API as an EU backend for German professional customers.
2. **§203/§62a/§43e chain.** Can Tinfoil and its GPU cloud providers be bound to secrecy in text form? tax-tech Get a legal opinion on whether attestation removes the "possibility of knowledge".
3. **Sub-processor list.** Tinfoil's list sits on trust.tinfoil.sh, which I could not read. Tinfoil's web-search docs say search "runs inside a secure enclave and talks directly to Exa, a search provider with Zero Data Retention", using a shared enclave-held API key so that "Exa only sees the enclave's IP address". Exa still receives the query text, so check this before advertising "private search".
4. **Web-search fee.** Tinfoil's docs say the fee "is charged once per request regardless of how many calls the model made", but give no price. The ~$0.05 figure is inferred from a docs example; confirm it in writing.
5. **Attestation verifier gaps.** Add freshness/revocation checks before selling to anyone. TEE.fail-class physical attacks belong in your threat model.
6. **Masking recall (14/22).** Publish the benchmark. Add a user review step and a "nothing detected ≠ anonymous" warning.
7. **Competitive moves.** Privatemode already targets regulated German industries; cybercompanyprofiles Confer and Meta could commoditise private chat. Re-check pricing quarterly.
8. **Secondary-source figures.** Some figures are now confirmed from primary or vendor sources:

- BRAK's own statistics give 167,547 lawyers on 1 Jan 2026 (166,504 on 1 Jan 2025).
- Beck-Noxtua prices (PLUS €299 / PREMIUM €499 per licence per month) are listed by ki-tools.com (Oct 2026).
- Privatemode's own trust docs say "Edgeless Systems is ISO 27001 certified". Its BSI C5:2026 claim ("meets the criteria") is a self-assessment, not a C5 attestation report. Hosting is on Scaleway (FR) and Lyceum (DE), and prompts are "processed exclusively within the EU".
- Still unconfirmed: the BPtK February 2026 "Administrative KI" practice note (reported only by a third-party blog).

What I Would Do First

1. **Weeks 1–4: fix the legal stack.**
   - Get Tinfoil's DPA, sub-processor list and EU-region answer, or prototype on Privatemode's EU API.
   - Draft a §62a StBerG / §43e BRAO / §203 StGB secrecy agreement template.
   - Commission a short legal opinion on the attestation-plus-masking architecture.
2. **Weeks 3–8: interview and test prices.** Interview 10 sole tax advisers and 10 small-firm lawyers (migration and family law first). Use the €29/€49/€79 test with a free 4-week pilot.
3. **Product.** Ship search quotas, a redaction review screen, and 5 profession-specific templates.
4. **Decision gate at month 3.** If fewer than 3 of 20 pay, pivot to Rank 3 (consultants/M&A) or to selling the redaction layer as a browser add-on on top of other providers.

Caveats

- Several price points come from competitors' or vendors' own pages and may be promotional.
- I found no 2025–2026 primary data on AI use among notaries, insurers, recruiters, financial advisers or therapists.
- Legal points summarise chamber guidance, not court rulings; the professional-law treatment of attested inference is untested.